

</ "img src="../../../frontend/assets/logo-lockup.svg" alt="Cornell Deep" width="300">

مصفوفة اختبار أمان الهوية — AuthShield 360 v2 (Enterprise)

خريطة التحقق الوظيفي لمتطلبات v2 (تسجيل + تحقق بريد حقيقي، تعيين جهاز موثوق، موافقة عبر جهاز آخر، خطر سياقي 0-100 مع الأسباب، شريط SOC الجانبي، هجمات A/B/C، لوحات مقسومة بالأدوار، بوابة مدرسية + RBAC، استرداد الحساب / إعادة ضبط MFA، التحقق الرقمي، بنشمارك المصادقة، بقاء البيانات بعد إعادة التشغيل). كل صف يطابق فحصًا قابلاً للتكرار عبر `scripts/smoke.js` أو `scripts/e2e-all.js` أو `scripts/ui-smoke.js` أو `scripts/restart-check.js`. إجمالي التغطية الآلية: **140** فحصًا.

TC-RSK — محرك الخطر التكيّفي (0-100، أسباب [])

المعرف	العامل	الوزن	النطاق	الدليل
RSK-01	F_TIME_ANOMALY (خارج 07:00–23:00)	15+	مرّكب	دفتر /api/factors/
RSK-02	F_NEW_IP (شبكة غير مرئية للمستخدم)	25+	مرّكب	دخول تصفّح خفي reasons=NEW_IP
RSK-03	F_NEW_DEVICE (بصمة غير معروفة) وحده	30+	LOW (≤ 30)	وحدة smoke للخطر
RSK-04	F_UNRECOGNIZED_DEVICE	30+	مرّكب	الموافقة عبر جهاز آخر تُظهر الأسباب
RSK-05	F_CONSECUTIVE_FAILURE لكل محاولة	20+	الثانية $\Rightarrow$ 40+	محاكاة Type-A: 55 $\rightarrow$ 75 حجب
RSK-06	F_IMPOSSIBLE_TRAVEL (< 1000 كم/دقيقة)	40+	مرّكب HIGH	محاكاة Type-B (SF $\rightarrow$ SYD) 12,000 $\approx$ كم)
RSK-07	F_BLACKLISTED_IP	45+	HIGH	محاكاة Type-C + قائمة سوداء يدوية
RSK-08	قصّ الدرجة	0–100	—	وحدة evaluateRisk
RSK-09	نطاق 0–30 LOW $\rightarrow$ مباشر (S1) / تصعيد S2	S3	—	S1 دافئ SUCCESS
RSK-10	نطاق 31–69 MEDIUM $\rightarrow$ موافقة عبر جهاز آخر / تراجع OTP+بريد	—	دخول خفي $\rightarrow$ PENDING_APPROVAL (درجة 55)	

المعرف	العامل	الوزن	النطاق	الدليل
RSK-11	نطاق 70-100 HIGH → إقفال فوري + تنبيه مشرف	—	نهايات Type-A/B/C + /api/dashboard ALERTS	

TC-VER — التسجيل → التحقق بالبريد → الجهاز الموثوق

المعرف	الخطوة	المتوقع	الدليل
VER-01	POST /auth/register	verification_pending , إصدار verifyUrl , كتابة Nodemailer (معاينة Ethereal متصلًا، وطرفية دون اتصال)	e2e + smoke
VER-02	تخزين رمز التحقق (استخدام واحد، TTL)	صف في verification_tokens	db
VER-03	=GET /verify?token	HttpOnly,) Set-Cookie as360_trust : email_verified=1 (SameSite=Lax , سنة)	e2e "cookie: "YES
VER-04	GET /me (مع الكوكي)	trusted:true + هوية المستخدم	e2e
VER-05	إعادة التحقق برمز منتهي/مستعمل	مرفوض	حراسة verifyEmail
VER-06	ثقة تلقائية بعد OTP لجهاز جديد	يُضاف صف device	auth.js \$SUCCESS

TC-XDA — الموافقة عبر جهاز آخر (بأسلوب Apple/Google)

المعرف	الخطوة	المتوقع	الدليل
XDA-01	دخول جهاز غير موثوق بخطر MEDIUM	PENDING_APPROVAL + pendingId + fallbackAt	e2e risk=55
XDA-02	الجهاز الموثوق يرى الطلب	حدث SSE cross:<uid (الجهاز، IP، الموقع، الخطر، الأسباب)	اختبار البث
XDA-03	موافقة	+ finalize → SUCCESS :pending → approved جلسة	e2e finalize SUCCESS
XDA-04	رفض	finalize :pending → denied (not_approved)	e2e
XDA-05	انتهاء المهلة	الحالة → expired :الواجهة تراجع إلى بريد + OTP	حراسة + pendingStatus الواجهة
XDA-06	الجهاز المُوَافَق يصبح موثوقًا	صف device لبصمة جديدة	finalize addTrustedDevice
XDA-07	الاستطلاع	GET /pending/:id/status	e2e

TC-SCN — سيناريوهات SRS الإلزامية (محفظة)

المعرف	السيناريو	المتوقع	الحالة
SCN-1A	S1 كلمة مرور صحيحة (موثوق، شبكة معروفة)	SUCCESS بلا MFA	ناجح
SCN-1B	S1 كلمة مرور خاطئة	FAILED_PASSWORD	ناجح
SCN-1C	S1 خطأ → إقفال؛ المحاولة الثالثة	HIGH_RISK_BLOCK	ناجح
SCN-2A	S2 كلمة مرور → تصعيد	STEP_UP needsOTP	ناجح
SCN-2B	S2 OTP صحيح	SUCCESS	ناجح
SCN-2C	S2 OTP خاطئ	INVALID_OTP (دون إقفال)	ناجح
SCN-3A	S3 كلمة مرور → تصعيد OTP + بريد	STEP_UP needsOTP+needsEmail	ناجح
SCN-3B	S3 كلمة مرور + OTP + بريد	SUCCESS	ناجح
SCN-3C	S3 RBAC	STUDENT → مسار مشرف HIGH_RISK_BLOCK	ناجح (يدوي)

TC-AUD — تدقيق مفصّل (كل محاولة)

الحقل	موجود	مثال
الطابع الزمني (ISO)	✓	2026-09-25T13:5x:xx.000Z
الهوية / الدور / المعرف	✓	...-teacher2 / TEACHER / usr
تسمية الجهاز + المتصفح/UA	✓	Unknown Device', desktop UA'
تجزئة البصمة	✓	...:fp
IP / الشبكة / التسمية	✓	San Francisco / - / 45.55.200.100
النتيجة	✓	SUCCESS / FAILED_PASSWORD / INVALID_OTP / STEP_UP / HIGH_RISK_BLOCK
الخطر 0-100 + الأسباب[]	✓	["NEW_IP","UNRECOGNIZED_DEVICE"] / 55

TC-SIM — محرك محاكاة الهجمات (A/B/C)

النوع	الاسم	القياس	الحالة النهائية
A	رشد القوة الغاشمة	3 محاولات خاطئة سريعة: خطر 55 → 75 → 100	حساب قيد الحجر، تنبيهات HIGH
B	اندفاع السفر المستحيل	دخول SF ثم SYD بعد 12 ثانية ⇒ سفر ≈ 12,000 كم	HIGH ⇒ إقفال
C	إعادة حقن بيانات مسروقة	كلمة مرور صحيحة من IP محظور + جهاز جديد	HIGH ⇒ حظر مهما كانت الكلمة صحيحة

كل المحاكاة تقود نفس أنبوب `attemptAuthentication` الحقيقي، وتبث كل مرحلة عبر SSE، وتحديث عدادات `api/alerts/` و `api/dashboard/` لحظيًا.

TC-SOC — لوحات مفرّقة حسب الدور

المعرف	الدور	السطح
SOC-01	ADMINISTRATOR	شريط جانبي (نظرة عامة/التدقيق/الجلسات/الأجهزة الموثوقة/عوامل التهديد/القائمة السوداء/محاكاة الهجوم)، مؤشرات، تنبيهات منبثقة

المعرف	الدور	السطح
SOC-02	STUDENT / TEACHER	مركز الأمان: حالة التحقق، أجهزتي (إلغاء)، جلسات (إنهاء)، آخر النشاطات

TC-RBA — البوابة المدرسية — الوصول المقيّد بالأدوار (v2)

المعرف	الفحص	المتوقع	النتيجة
RBA-01	GET /api/portal/session دون جلسة	401 SESSION_REQUIRED	e2e
RBA-02	درجات/مقررات/حضور الطالب	200، بياناته فقط	e2e
RBA-03	قوائم/دليل/مصفوفة الطالب	403 PORTAL_RBAC_DENIED	e2e
RBA-04	قوائم المعلم	200 (مقرراته)	e2e
RBA-05	مصفوفة/دليل المعلم	403	e2e
RBA-06	مصفوفة المشرف	200، 8 وحدات	e2e + ui-smoke
RBA-07	دليل/قوائم المشرف (كل الصفوف)	200	e2e
RBA-08	تخصّص SQL للبيانات (فلتر معلم/شبكة)	حقن مرشّح الصفوف	مراجعة portal.js/db.js
RBA-09	قفل مسار الطالب في سيناريو 3	+ HIGH_RISK_BLOCK UNAUTHORIZED_ROUTE	e2e
RBA-10	بوابة لوحة تحكم المشرف (قوائم/عوامل/تحقيق)	403 ADMIN_SESSION_REQUIRED دون SID نشط	e2e

TC-REC — استرداد الحساب / إعادة ضبط (v2) MFA

المعرف	الخطوة	المتوقع	النتيجة
REC-01	POST /api/recovery/request	ok ، رمز تحقق 6 خانات، محفوظ	e2e
REC-02	إعادة ضبط برمز خاطئ / كلمة ضعيفة	مرفوض	e2e
REC-03	POST /api/recovery/reset	تدوير TOTP، تغيير كلمة المرور، 10 رموز أحادية الاستخدام	e2e
REC-04	POST /api/recovery/validate (رمز مرة واحدة)	الأولى ok ، الثانية false (أُستهلك)	e2e
REC-05	الدخول بكلمة المرور الجديدة	SUCCESS (الجهاز ما زال موثوقًا)	e2e

المعرف	الخطوة	المتوقع	النتيجة
REC-06	الدخول بكلمة المرور القديمة	FAILED_PASSWORD	e2e
REC-07	سجل التدقيق	RECOVERY_REQUEST/RESET/CODE_VALID صفوف	e2e §12

TC-FOR — التحقيق الرقمي (v2)

المعرف	الخطوة	المتوقع	النتيجة
FOR-01	GET /api/forensics/summary	عُذادات حيّة (تدقيق/جلسات/أجهزة/قضايا)	e2e
FOR-02	GET /api/forensics/timeline? =user	أحداث زمنية (kind/ref/ts)	e2e
FOR-03	إنشاء قضية (التقاط تلقائي)	case.id + عناصر أدلة ملتقطة	e2e + ui-smoke
FOR-04	سرد القضايا	عُداد items لكل قضية	e2e
FOR-05	خط زمني للقضية	أدلة من صفوف التدقيق الملتقطة	e2e
FOR-06	إغلاق القضية	الحالة CLOSED	e2e
FOR-07	تصدير الأدلة	ok + markdown (# Forensic Case, Evidence timeline)	e2e + restart-check
FOR-08	حذف القضية	تختفي من السرد	e2e

TC-BEN — بنشمارك المصادقة (v2)

المعرف	الفحص	المتوقع	النتيجة
BEN-01	GET /api/benchmark	3 ، ok سيناريوهات	e2e
BEN-02	لكل سيناريو	محاولات ≤ 1 ، averageLoginTimeMs ، عُدّاد النجاح	e2e
BEN-03	قياس من elapsed_ms حقيقي	بلا بيانات مصنّعة	benchmark.js + restart-check مراجعة

TC-NFR — بقاء البيانات بعد إعادة التشغيل (v2, التوفر)

المعرف	الفحص	المتوقع	النتيجة
NFR-01	إعادة تشغيل قاسية على نفس ملف SQLite	المستخدمون + الأجهزة الموثوقة تصمد	restart-check
NFR-02	سجل التدقيق (بما فيه elapsed_ms) يصمد	العدد $\leq$ قبل إعادة التشغيل	restart-check

المعرف	الفحص	المتوقع	النتيجة
NFR-03	الجلسات / الأجهزة تصمد	العذادات ثابتة	restart-check
NFR-04	أسرار TOTP تصمد	الدخول أمكن بعد إعادة التشغيل	restart-check
NFR-05	قضايا التحقيق + الأدلة تصمد	القضية والتصدير يعملان	restart-check
NFR-06	عمليات الهجوم تصمد	السجل التاريخي سليم	restart-check

ملاحظات الأدوات

- المكافئ اليدوي 1:1 مقابل واجهة JSON العامة — Burp Suite / OWASP ZAP تستهدف `*/http://localhost:4000/api`.
- لرفع حراسة القوة الغاشمة أثناء الاستطلاع: ادخل ك `admin` (S3، رمز DEMO)، ثم `PUT /api/security-policy?standby=false` و `POST /api/arm-mode (x-session-side: <sid>)`.
- الحزام الآلي: `scripts/smoke.js` (17؛ بلا خادم)، `scripts/e2e-all.js` (77؛ خادم حي)، `scripts/ui-smoke.js` (28؛ متصفح حقيقي)، `scripts/restart-check.js` (18؛ منفذ معزول 4001). وصفة التشغيل النظيفة: إيقاف `4000` ← `npm start` ← `node scripts/reset-db.js` ← تشغيل السويتات الأربعة.